

TwinaForms ZAP Scope Note

Date: 2026-08-20

Package release context: TwinaForms managed package 0.14.0.1 , package version id 04tgL000000009FQAW .

These OWASP ZAP reports are passive requestor scans for ISV evidence. The ZAP Automation Framework requestor job was used to send known safe requests to each target, and the reports were generated with the risk-confidence-html template.

Scope

The scan scope covers the current TwinaForms public/runtime surfaces used by the released managed package 0.14.0.1 :

- published public form page on forms.twinaforms.com
- public prefill Lambda Function URL
- public submit Lambda Function URL
- Salesforce-to-AWS backend Lambda Function URL
- submission logs Lambda Function URL
- TwinaForms Admin API Lambda Function URL
- portable snapshot import/export backend routes:
 - POST /portable-snapshots/latest
 - GET /portable-snapshots
 - GET /portable-snapshots/{sourceOrgId}/{globalFormKey}

The protected backend, submission-log, admin API, and portable snapshot routes were intentionally scanned without tenant bearer secrets or Cognito JWTs. The purpose is to demonstrate unauthenticated rejection without exposing credentials in scanner reports.

Scan Type

No active attack scan was run for this evidence packet. No tenant bearer secret, OAuth refresh token, Cognito token, Salesforce session id, or real customer credential is included in the plans or reports.

The new import/export coverage verifies that portable snapshot routes reject unauthenticated requests with 401 Unauthorized . This protects imported/exported form snapshot data from public unauthenticated access.

Evidence Locations

- Automation plans: retained in this dated project evidence folder.
- Official reports: attach reports 01-07 with the submission packet.

- Response notes: included in this documentation upload packet.

Reviewer Disposition

The reports are intended as DAST support evidence for the ISV security review packet. Findings are triaged in `TwinaForms_ZAP_ISV_Response_2026-08-20.md` .